arXiv:2611.06294v1 [cs.CR] 4 Nov 2026

A.S.E 2.0: Understanding How Repository Context Impacts the Security of LLM-Generated Code

Jiongchi Yu*
jiongchiyu@acm.org
Nanyang Technological University
Singapore, Singapore

Keke Lian*
kekelian@tencent.com
Tencent
China

Junqing Wang
wangjunqing388@gmail.com
Zhejiang University
Hangzhou, China

Zhikang Fan
15030857023@163.com
Zhejiang University
Hangzhou, China

Zhaoxuan Li
lizhaoxuan@iie.ac.cn
IIE, CAS
Beijing, China

Yongheng Huang
yonghenghuang384@gmail.com
Tencent
China

Ziming Zhao†
zhaoziming@zju.edu.cn
Zhejiang University
Hangzhou, China

Dong Zhang†
zalezhang@tencent.com
Tencent
China

Abstract

Large language model (LLM) coding assistants and agents construct a repository context before generating code. For security-sensitive code, this context decides whether the model sees the project's safeguards (e.g., authorization checks) or insecure code to imitate. However, context construction is designed almost exclusively for functional correctness, and secure-code benchmarks treat the context as fixed, so how repository context affects the security of generated code remains unclear. We construct CASE-Bench, a benchmark of 145 repository-level tasks from real CVEs in 51 projects. Each task runs in Docker, has functional tests and a proof-of-concept exploit validated in both directions, and is annotated with the repository code that enforces or undermines its security. Using CASE-Bench, we compare 13 context construction methods and six controls with six LLMs, edit single context elements, and analyze coding-agent trajectories. We find that ❶ functionality-oriented context raises the functional pass rate by up to 8.2 percentage points (pp) but the secure pass rate by at most 3.7 pp, ❷ withholding a safeguard lowers the secure pass rate by up to 8.1 pp, while one inserted insecure exemplar raises correct-but-exploitable code by 6.3 pp, and ❸ coding agents observe the relevant safeguard in only 27-36% of trajectories. These findings inform security-aware context construction and secure-code evaluation.

CCS Concepts

• **Software and its engineering** → **Software verification and validation**; • **Security and privacy** → **Software and application security**.

Keywords

Secure code generation, repository-level code generation, context retrieval, coding agents, large language models, empirical study

ACM Reference Format:
Jiongchi Yu, Keke Lian, Junqing Wang, Zhikang Fan, Zhaoxuan Li, Yongheng Huang, Ziming Zhao, and Dong Zhang. 2026. A.S.E 2.0: Understanding How Repository Context Impacts the Security of LLM-Generated Code. In . ACM, New York, NY, USA, 15 pages. https://doi.org/10.1145/nnnnnnn.nnnnnnn

1 Introduction

LLM coding assistants and agents rarely generate code from the prompt alone. They first assemble *context* from the repository (e.g., similar code or imported definitions) [36, 60, 66, 69]. For security-sensitive code, the information that makes an implementation safe is often not local: a parser may need the zero-divisor check of a sibling routine, and an endpoint may need a project-specific permission. Context construction therefore decides whether the model sees the repository's security policy, and it can also expose legacy code with the same weakness (§2.2).

Context construction has nevertheless been designed and evaluated almost exclusively for functional correctness [17, 27, 63, 69]. Secure-code benchmarks have moved from snippets [3, 47, 53] to real repositories [5, 32, 49, 61, 72], and RealSec-bench [61] observes that retrieval improves correctness more than security. However, existing benchmarks cannot explain *how* context affects security, because most of them share four limitations. ❶ *Context is fixed, not studied.* They evaluate one context configuration or compare a few retrievers, so no benchmark explains which context properties cause the gap between correctness and security. ❷ *Security oracles are static or untargeted.* Many benchmarks judge security

*Both authors contributed equally to this research.
†Corresponding authors.

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than the author(s) must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from permissions@acm.org.
Conference'17, Washington, DC, USA
© 2026 Copyright held by the owner/author(s). Publication rights licensed to ACM.
ACM ISBN 978-x-xxxx-xxxx-x/YYYY/MM
https://doi.org/10.1145/nnnnnnn.nnnnnnn

with static rules or LLM judges [19, 32, 61], which miss runtime-dependent weaknesses and cannot show that the specific weakness is exploitable. ❸ *Functionality is not validated jointly.* Without functional tests, broken or deny-all code can look secure [32, 53]. ❹ *Security-relevant context is not measurable.* No benchmark records which repository code enforces or undermines security, so outcomes cannot be attributed to the content of a context.

To address these limitations, we construct CASE-Bench, a benchmark of 145 repository-level generation tasks derived from 144 real CVEs in 51 open-source projects. The tasks are *diverse*, covering 28 CWEs in seven languages, and they span *different difficulty levels*, from generic checks to project-specific policies. They are also of *high quality*: every task is reproducible in a Docker environment, and its functional tests and proof-of-concept (PoC) exploit are validated against both the vulnerable and the patched version (❷, ❸). Two experts annotated the security-relevant repository code of every task (❹). On CASE-Bench, we hold the task, prompt, and oracle fixed and vary only the context (❶). We compare 13 context construction methods and six controls with six LLMs, edit single context elements, and analyze what coding agents observe. Our study answers the following research questions:

- **RQ1: How do context construction methods affect the correctness and security of generated code?** We measure the functional and secure pass rates of real methods against the target file alone and against security controls.
- **RQ2: Which context properties make context help or hurt security?** We edit single context elements, such as safeguards or insecure exemplars, and analyze why code remains insecure.
- **RQ3: Do coding agents gather security-relevant context?** We analyze what agents search for and observe, and how this relates to the security of their code.

We additionally check whether the conclusions depend on the security oracle.

Our study shows that functionality-oriented context raises the functional pass rate by up to 8.2 percentage points (pp) but the secure pass rate by at most 3.7 pp, with no significant difference from the target file alone. Context helps when it exposes concrete safeguards: withholding a safeguard lowers the secure pass rate by up to 8.1 pp, whereas a security-themed placebo has almost no effect. It hurts when it exposes insecure exemplars, one of which raises correct-but-exploitable code by 6.3 pp even with the safeguard present. Coding agents share this bias toward functionality, observing the relevant safeguard in only 27-36% of their trajectories.

Contributions. In summary, we make three contributions:

- We construct CASE-Bench, an executable benchmark whose tasks are validated in both directions, solvable within the edit scope, and annotated with security-relevant repository code.
- We conduct a controlled study of 13 context construction methods and six controls with six LLMs (49,590 generations), which extends the functionality-security gap reported for a few retrievers to all major method families.
- Through single-element context edits, failure patterns, and 1,305 agent trajectories, we show which elements change security and derive guidelines for security-aware context construction.

2 Problem and Motivating Example

2.1 Problem Formulation

Task and context. A task comprises a repository at the last vulnerable commit, a target file with a removed code region (the *masked region*), and a requirement that specifies its functionality. The model must regenerate the masked region and is never told that the task is security-relevant (§3.1). A context construction method selects repository units (e.g., functions) to accompany the requirement and the masked target file.

Outcomes. Each generated implementation is built, tested, and attacked with the task's exploit, and it receives one of four outcomes: *Unbuildable*, *Incorrect* (a functional test fails), *correct but exploitable* (CbE: all tests pass, but the exploit succeeds), or *Secure* (all tests pass, and the exploit shows no effect). Both labels are relative to the task's oracles: "correct" means passing the provided tests, and a failed exploit does not rule out other vulnerabilities (§3.2).

Context effect. Let $SecRate(s, t)$ be the fraction of runs in which method s yields a secure implementation of task t. The context effect of s on t is $\Delta(s, t) = SecRate(s, t) - SecRate(\text{Local-only}, t)$, where Local-only shows the model only the target file. All else fixed, systematic differences in Δ are attributable to the context, while differences over three runs also contain sampling noise (§4.4).

2.2 Motivating Example

Figure 1 shows a task derived from CVE-2021-20205, a divide-by-zero vulnerability in the GIF reader of libjpeg-turbo. The requirement asks for parsing the image dimensions but does not mention that they may be zero, whereas the other image readers of the same repository reject zero dimensions. With four functionality-oriented contexts that lacked such a check, the code of GPT-5.4 passed all tests but was exploited by a zero-width GIF in every run. With the ReACC-Hybrid context, which contained the guard of the Targa reader, the model reproduced the guard and was secure in every run. Similarity retrieval exposed the guard here, but it could equally have retrieved an unchecked sibling; our controlled context edits separate these effects.

2.3 How Context Can Help or Hurt

As an analysis framework, we relate each context unit to the *security policy* that the masked region must enforce (e.g., a bounds check or an authorization rule). A unit may serve several roles, and some units remain unclassified. From prior work, we derive four candidate mechanisms, which we treat as hypotheses.

Exposure. A unit that enforces the policy (a *safeguard*) can help: retrieved APIs improve correctness [17, 27], and retrieved secure examples improve function-level security [34, 51, 68].

Imitation. A unit that violates the policy (an *insecure exemplar*, e.g., an unfixed sibling) can hurt: surrounding code changes the security of suggestions [45], and planted vulnerable examples induce vulnerable code [33].

Dilution. Unrelated units and long contexts can bury a safeguard [11, 35, 50].

Priming. Security-themed text that does not apply to the target may change the output by itself [56], which confounds the evaluation of security-aware methods.

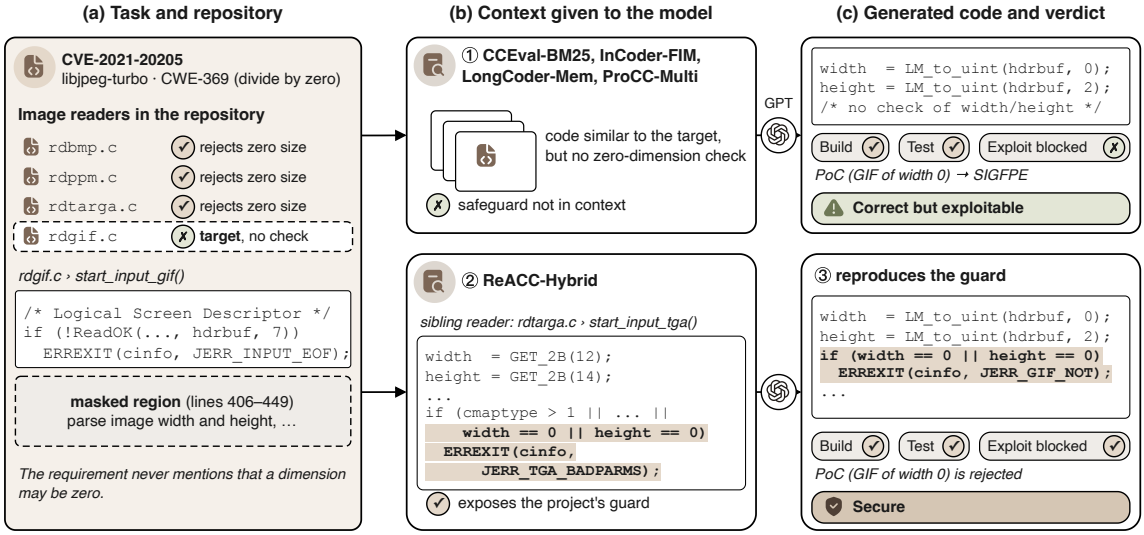

Figure 1: CVE-2021-20205. (a) Sibling image readers check for zero dimensions; the GIF reader does not. (b, c) With the model, task, and prompt fixed, ① four contexts yield correct-but-exploitable code, whereas ② ReACC-Hybrid retrieves the Targa guard and ③ the generated code reproduces it. Outcomes hold across all runs.

3 CASE-Bench

3.1 Task Construction and Validity

CASE-Bench was built by ten security experts (five Ph.D. and five M.S. students with at least two years of experience in vulnerability analysis) in five steps (Figure 2); every manual step was performed independently by two experts.

Selection. We collected reproducible CVEs (e.g., with a public PoC) and prioritized the CWE Top 25 and OWASP Top 10. We excluded fixes that change more than ten files, because they cannot be localized to one coherent region; 488 of 1,236 records passed this screening. Because rebuilding a historical environment takes several person-hours, we selected 236 candidates by two criteria. *Reproducibility* requires that the base commit builds with an available toolchain and that the PoC replays in an isolated container. *Diversity* balances weakness types and code bases while limiting near-duplicate CVEs. This purposive sample favours reproducible CVEs, and it used only CVE metadata, never model outputs. We admitted 144 CVEs (145 tasks); most rejections stemmed from build failures of old commits (41), PoCs that did not reproduce (30), or vulnerable code that spanned no coherent region (21).

Task definition. An expert identified the base commit (the parent of the fix) and the vulnerable region that the fix changes, which becomes the masked region (1 to 1,207 lines, median 10). The expert then wrote a requirement that specifies the intended behaviour (e.g., inputs and intended users) but names no attack or defense. Requirements were drafted with an LLM; two experts audited all of them and rewrote 23. Requirements do not restate policies defined in the visible repository, and the derivability annotation (§3.3) records whether the security property can be inferred from the available information. In the 51 *multi-location* tasks, the fix also changes other files, which stay at the vulnerable version.

Information barrier. The model receives the requirement, the target file with a placeholder for the region, and the context, and it returns a unified diff. It never sees vulnerability information (e.g., the CVE identifier or the fix) or our evaluation artifacts (e.g., the tests). Context methods retrieve only from the *visible repository*, i.e., the base snapshot stripped of the masked region and of any trace of the vulnerability (e.g., the commit history). Because the snapshot precedes the fix, it may contain *insecure exemplars* (e.g., unfixed siblings with the same weakness). We keep and annotate them, as real repositories contain such code (74 tasks).

Contamination. We flag near-copies of the vulnerable or patched region (edit similarity ≥ 0.9), build semantics-preserving variants of 40 tasks [65], and report 19 tasks from 2024 or later separately.

3.2 Executable Evaluation

Each generation is evaluated in a fresh container in three stages. **Build:** the diff applies, and the project builds and starts (timeout 5 min). **Functional tests:** all expert-written tests pass (4.6 inputs per task on average; timeout 2 min). The tests cover typical and boundary inputs (e.g., benign inputs along the PoC path), so deny-all code fails them; correctness remains relative to these tests. **Exploit:** the PoC is replayed (timeout 2 min), and exploitation is decided by an observable effect, e.g., a sanitizer report for memory-safety weaknesses [29, 40] or an unauthorized action for web weaknesses, so secure implementations that differ from the historical fix are not penalized [28]. Each PoC defines its effect check in advance, and *Secure* requires that the PoC completes without that effect; infrastructure failures trigger re-execution rather than a verdict. For 40 tasks sampled by CWE family, we wrote three exploit variants each (e.g., encoded payloads). For comparison with static evaluation (§5.4), we also run CWE-specific CodeQL and Joern queries [16, 25] and count only alarms whose path crosses the regenerated region.

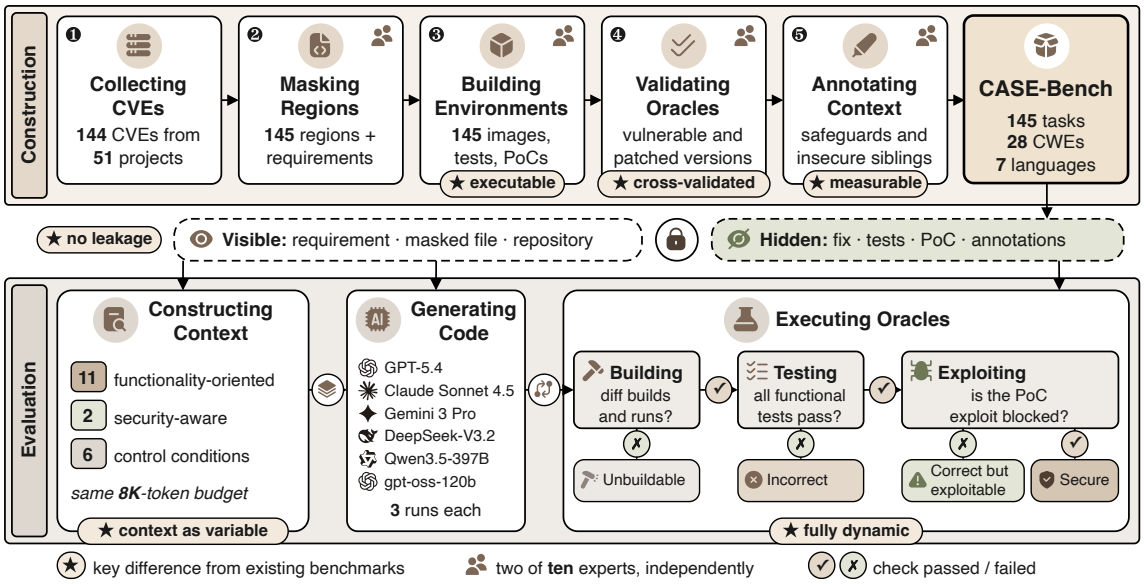

Figure 2: Overview of CASE-Bench: construction (top), the model–evaluation information barrier (middle), and controlled evaluation (bottom). ★ marks properties compared with prior benchmarks in §7.

Table 1: Oracle validation (all 145 tasks unless stated otherwise).

Check	Criterion	Result
V1 Vulnerable version	builds, tests pass, PoC succeeds	145/145
V2 Patched version	builds, tests pass, PoC fails	145/145
V3 Alternative secure implementation	builds, tests pass, PoC fails	143/145
V4 Deny-all implementation	tests fail	145/145[a]
V5 Determinism	identical verdicts	145/145[b]
V6 Manual audit	agreement / Cohen's κ [9]	95.7% / 0.90

[a] after strengthening the tests of 6 tasks; [b] after stabilizing the start-up scripts of 3 tasks.

Oracle validation. Table 1 summarizes the validation. An independent reviewer first wrote the alternative implementation (V3) and then reviewed and replayed the task on both versions (V1, V2); 38 tasks needed a second review round, and 9 of them a third. V3 has two purposes. It checks that the oracles do not overfit the historical fix, because the reviewer wrote the alternative before seeing the patch. It also checks solvability within the edit scope, because the alternative replaces only the masked region while all other files stay vulnerable, which matters for multi-location tasks. The two tasks that fail V3 remain solvable within this scope, since the patched region alone passes all checks. V1 shows that the tests do not encode the security property, V4 that deny-all code cannot score as secure, and V6 that the verdicts agree with manual exploitation.

3.3 Context Annotations and Dataset Profile

Two experts independently annotated every task, and a third resolved disagreements (κ over each task's candidate units).

Security roles ($\kappa = 0.82$). *Flow roles* (source and sink) locate the attack path, *enforcement roles* (e.g., a validator or safe API) implement a check, and the *policy* role defines what is allowed. A *safeguard* is a unit with an enforcement or policy role, and a task's *acceptable safeguard sets* include the historical fix and annotated alternatives. An *insecure exemplar* processes the same untrusted input without a guard and is exploitable in the same way. Safeguards and the source-sink path form the task's *reference context*.

Security locality ($\kappa = 0.79$). It measures how much a secure solution needs the repository: generic built-ins suffice at **L1**, a project API is needed at **L2**, and a repository-specific rule decides at **L3**.

Derivability ($\kappa = 0.77$). It records whether the security property follows from the requirement and target file (38 tasks), from the reference context (99), or from neither (8). We also extract *fix-relevant APIs*, i.e., definitions that the patched region references; as they follow the historical fix, their recall is only a functional proxy.

Profile. CASE-Bench covers 28 CWEs, including 20 of the 2024 CWE Top 25, in four families led by memory safety (65 tasks) and injection (42) (Figure 3). The tasks span seven languages and all three locality levels (41, 67, and 37 tasks at L1 to L3). Locality differs by family: access-control tasks are almost all L3, whereas most memory-safety tasks are L1 or L2. Six projects contribute 67 tasks,

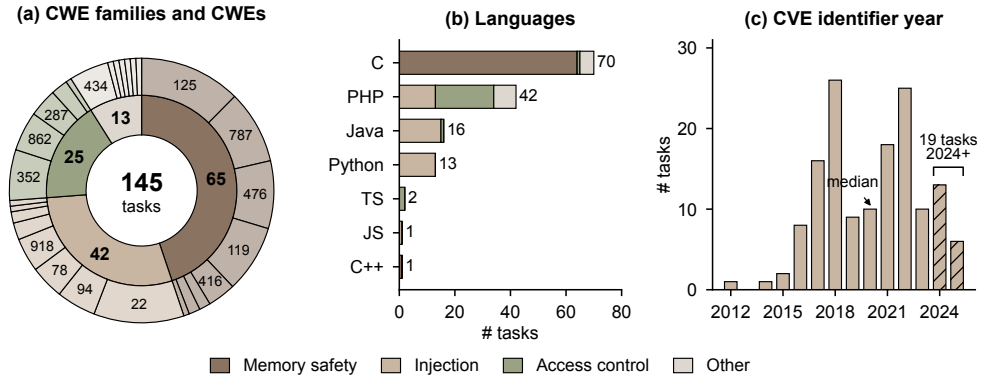

Figure 3: Distribution of the 145 tasks. (a) CWE families (inner ring) and CWEs (outer ring). (b) Languages by family. (c) Year of the CVE identifier; hatched: 2024 or later.

so we treat the project as the unit of clustering in all statistical analyses. The median project has 86 KLOC (1.1M tokens), and only 6% of projects fit into a 128K-token context. The CVEs date from 2012 to 2025 (median 2020), and 19 tasks stem from 2024 or later, which reduces the risk that all tasks were seen during training.

4 Study Design

4.1 Context Conditions

Methods. We selected eleven *functionality-oriented* methods that are published or deployed in widely used tools and that cover all major retrieval families (Table 2). We compare their *context policies* as reproduced in a common pipeline, not the original systems, and name each policy after its source (e.g., CCEval-BM25 for CrossCodeEval). We add two *security-aware* methods. CodeGuarder [34] injects external security knowledge mined from vulnerability databases, rebuilt without the CVEs of CASE-Bench. Source-sink slicing probes *repository-internal* security context: following data-flow-guided retrieval [8], it retrieves the path from untrusted input to a sensitive operation together with its guards. It uses only the generic CodeQL and Joern models, never the oracle's queries, and proceeds in five steps. ❶ *Anchoring:* sources are untrusted values that reach the inputs of the masked region, and sinks are sensitive operations reachable from the code that consumes its result. ❷ *Candidates:* the analysis collects the paths between them within two call-graph hops, together with their guards, i.e., conditions that decide whether execution reaches the sink. ❸ *Request semantics:* for web applications, paths link an endpoint to the forms that call it, and guards are recognized by the return values and state that decide whether a request proceeds (e.g., an early exit on a failed permission check), so project-specific wrappers need no hand-written models. ❹ *Ordering:* shortest paths come first, each as its guards followed by its units in flow order, until the cap. ❺ *Failure:* without a path, no units are returned, and the prompt equals Local-only. For OpenEMR (§5.5), step ❸ links the amendment request to its form and retrieves the guard *aclCheckCore('patients', 'amendment', ...)*; the implementation and all slices are released.

Common pipeline. Each method receives the requirement, the masked target file, and the visible repository, and it returns an ordered list of units. We keep each method's ranking logic and hyperparameters and replace only language-specific parts (e.g., parsers by tree-sitter grammars), so for newly supported languages the policy is inspired by, not validated against, the original. Every prompt contains the task inputs (e.g., the complete masked target file) and a context block, which is empty for Local-only. The units are deduplicated among themselves, serialized in rank order, and truncated at a *common retrieval cap* of 8K tokens that excludes the target file. The cap equalizes neither length nor cost, so we report actual sizes (Table 2) and native budgets. Deduplication does not remove code that repeats the target file, so the in-file methods differ from Local-only: InCoder-FIM re-presents the code around the region next to the generation point, and LongCoder-Mem adds imported declarations, which raises fix-API recall from .12 to .19. Generator-independent contexts are cached and identical across models and runs.

Controls. Six conditions anchor and de-confound the comparison. **Local-only** shows the masked target file alone and is the reference for all context effects. **BM25+README**, the configuration of A.S.E [32], anchors our results to a prior evaluation. **Repo-128K** serializes the visible repository from the target's directory outward in the format of repository-level benchmarks [10, 36] and truncates it so that the complete prompt and an output reserve fit into the smallest window among our models (118K tokens of content on average); as only 6% of projects fit, it is a truncated repository, not the full one. The **Reference context** contains exactly the annotated safeguards and source-sink path; it is a diagnostic, not an upper bound. The **Security reminder** and the **Placebo** add a security instruction or security-themed code from another project, respectively; they bound rather than isolate priming, because foreign code may still convey generic checks.

4.2 Models, Generation, and Metrics

We evaluate six generator LLMs from five developers, three proprietary (e.g., GPT-5.4) and three open-weight (e.g., Qwen3.5-397B-A17B). Reasoning models use the providers' default settings, and the two non-reasoning configurations use temperature 0.2. All conditions share one prompt skeleton and run three times per task.

Table 2: Context construction methods and conditions. "Gen.-dep.": the context depends on the generator model. "Tokens": mean context size beyond the masked target file, at the 8K retrieval cap (Repo-128K: 128K). "Fix-API": mean fraction of fix-relevant APIs whose definitions are in the prompt, including the masked target file (hence non-zero for Local-only).

Family	Method	Context policy (as reproduced)	Gen.-dep.	Tokens	Fix-API
Reference/ control	Local-only	masked target file only	-	0	.12
	BM25+README [32]	BM25-ranked files + README	-	7.6K	.29
	Repo-128K	serialized repository, truncated to 128K tokens	-	118K	.63
	Security reminder	Local-only + generic security instruction	-	0	.12
	Placebo	Local-only + security code of another project	-	3.9K	.12
	Reference context	annotated safeguards + source-sink path	-	2.7K	1.00
In-file	InCoder-FIM [13]	prefix and suffix around the masked region	-	3.1K	.14
	LongCoder-Mem [18]	long in-file window; imports/globals as memory	-	6.8K	.19
Similarity	ReACC-Hybrid [38]	similar code, hybrid lexical + dense retrieval	-	7.8K	.38
	CCEval-BM25 [10]	cross-file chunks by BM25 on the in-file prefix	-	7.9K	.27
	RepoBench-R [36]	imported cross-file definitions, ranked	-	5.2K	.33
	ProCC-Multi [55]	LLM-prompted retrievers chosen by a bandit	✓	7.7K	.36
Iterative	RepoCoder-Iter [69]	retrieval re-queried with a draft completion	✓	7.9K	.34
Structure	RLPG-Proposal [52]	prompt proposals (imports, siblings, parents)	-	6.4K	.31
	DevEval-Dep [30]	local file + extracted dependencies	-	6.1K	.42
Agentic	SWE-agent-Ret [66]	regions found by SWE-agent's search tools	-	6.9K	.35
	ClaudeCode-Ret	regions selected by Claude Code (Read/Grep)	-	7.2K	.47
Security-aware	CodeGuarder [34]	retrieval + external security knowledge	-	7.5K	.33
	Source-sink	CWE-agnostic source→sink slice + guards	-	4.1K	.74

RQ1 has 49,590 generations, RQ2 adds 49,140 with three models, and RQ3 adds 1,305 agent trajectories (total cost USD 38,000).

Metrics. For a task set T and $n = 3$ runs per task, SecPass@1 = $\frac{1}{|T|}\sum_{t\in T} secure(t)/n$, where $secure(t)$ counts the secure runs on t; this is the unbiased pass@1 estimator [7] with "secure" as the success criterion [49]. FuncPass@1 and CbE@1 are defined analogously, so FuncPass@1 = SecPass@1 + CbE@1. SecPass@1 is our primary metric and CbE@1 our primary risk metric; differences are reported in percentage points (pp). Before generation, we characterize each prompt with context metrics (e.g., whether it covers an acceptable safeguard set).

4.3 Interventions, Agents, and Failure Patterns

RQ2: context edits and failure patterns. We vary the retrieval cap from 1K to 32K tokens for four methods, and we apply single-element edits to two base contexts, the Reference context and the context of the best functionality-oriented method. Each edit is compared with its unmodified base on all eligible tasks. Remove and Add delete one safeguard role or insert the missing safeguards; because a removed safe API may also carry functional knowledge, we report CbE@1 next to SecPass@1. Insecure inserts one naturally occurring insecure exemplar at a random position (74 tasks), and we never synthesize vulnerable code. Distract appends irrelevant code of 2K to 32K tokens. Two *matched controls* replace a removed role, or the inserted exemplar, with irrelevant code of the same length at the same position, which separates content from length and position. Finally, Position moves the safeguard within contexts of 4K to 64K tokens, and Rename gives it a neutral name repository-wide.

To explain why code remains insecure, each correct-but-exploitable generation receives one or more of five failure labels (Table 5); for example, Unused means that a safeguard is present but neither called nor replicated, and Imitated requires an AST similarity of at least 0.7 to an exemplar in the context. Equivalent checks are detected with the guard analyses of CodeQL and Joern [16, 25]. Two authors labeled a stratified sample of 200 generations manually, and we also compare the dominant labels of two methods within each task-model pair, which avoids changes in the denominator. The labels describe co-occurrence, not cause.

RQ3: agents. We run SWE-agent [66] with two backbones and Claude Code, three runs per task, in an isolated sandbox (e.g., without network access). Agents may explore and run the whole repository but edit only the masked region (at most 50 steps and USD 2 per task). This restriction keeps the task one of secure *generation*, since edits elsewhere would turn it into repository-wide repair, and it keeps agents comparable with retrieval-based methods. The *observed context* of a trajectory is every region that a tool returned to the agent after output truncation. Observed tokens accumulate over the trajectory, so they do not measure a single prompt, and we do not track whether a region remains in the agent's context at its final edit. For each trajectory, we record whether the safeguard was observed before the first edit of the masked region and whether the run hit the step or cost cap. Search queries are classified automatically as functional or security-related; identifiers (e.g., wrapper names) count as functional unless they contain a security term, and two authors validated this classification on 300 queries.

Oracle comparison. We cross-tabulate static and exploit verdicts for all functionally correct RQ1 generations, calibrate the static queries on the known versions of each task, and compare method rankings on the same 145 tasks.

4.4 Statistical Analysis

Because tasks are clustered within projects [1], we report 95% cluster-bootstrap intervals over the 51 projects [12] and test with

logistic mixed-effects models [2] with random intercepts for project, task, and task-model pair. We test 18 pre-specified comparisons with Holm correction [22]: each of the 13 methods against Local-only, the two security-aware methods against both priming controls, and the Reference context against the best functionality-oriented method. We regard differences of at least 3 pp as practically relevant, a threshold fixed before the analysis. The best method is selected on the same data, which makes the Reference-versus-best difference conservative. A power analysis on a pilot run showed 80% power for 5.6 pp after correction, so a nonsignificant result does not establish the absence of an effect. We compare rankings with Kendall's τ_b [26] and report Cohen's κ [9] for manual annotations. All other analyses (e.g., robustness checks and agent analyses) are exploratory and reported as estimates; runs that fail for infrastructure reasons are re-executed, and outputs are never resampled based on their content.

5 Results

5.1 RQ1: How Does Context Construction Affect Correctness and Security?

Functionality-oriented context yields limited security gains. Relative to Local-only, the eleven functionality-oriented methods change FuncPass@1 by −4.8 to +8.2 pp but SecPass@1 by only −1.1 to +3.7 pp (Table 3, Figure 4). Only ClaudeCode-Ret reaches the 3 pp threshold, and no method differs significantly from Local-only after correction (ClaudeCode-Ret: OR 1.35, $p_{\text{Holm}} = .19$); smaller effects cannot be ruled out. Four methods even have lower observed SecPass@1 than Local-only, and 40.3-50.2% of all generations are correct but exploitable. This pattern replicates the observation of RealSec-bench [61] for Java retrievers and extends it to all major method families.

Correctness-optimal is not security-optimal. ProCC-Multi has the highest FuncPass@1 (65.1%) but ranks only third in SecPass@1, because correct-but-exploitable code accounts for 72% of its functional gain. CCEval-BM25 and Repo-128K even raise CbE@1 by more than FuncPass@1, so their additional working code is exploitable on balance. The rankings by FuncPass@1 and SecPass@1 agree only moderately ($\tau_b = 0.48$), and a cross-fitted oracle that picks the best method per task exceeds the best single method by 3.3 pp, so the methods are complementary.

Security-aware context helps, depending on the weakness. CodeGuarder adds 4.2 pp (OR 1.40, $p_{\text{Holm}} = .07$) and Source-sink 5.5 pp (OR 1.53, $p_{\text{Holm}} = .006$), and both lower CbE@1 below Local-only. Their advantages over the priming controls are not significant after correction, but the Placebo changes SecPass@1 by only 0.3 pp, and the Security reminder adds 1.3 pp while lowering FuncPass@1 by 1.8 pp because some generations reject benign inputs. The Reference context adds 12.2 pp, 8.5 pp more than the best functionality-oriented method (OR 1.69, $p_{\text{Holm}} = .001$), and Source-sink recovers 4% of the Local-only-to-Reference gain. By CWE family (Table 4), CodeGuarder is strongest on memory safety, where generic checks transfer, whereas Source-sink is strongest on access control (9.3% vs. 3.1%), where security depends on project policies. These are method-level comparisons, since the two methods also differ in retrieval logic and context length. By locality, the best functionality-oriented method gains +2.0, +6.4, and +0.8 pp on L1 to L3 tasks, whereas Source-sink gains +1.8, +6.8, and +7.4 pp and the Reference context +3.8, +14.8, and +17.0 pp. Similarity retrieval thus occasionally surfaces a project API (L2) but almost never a project policy (L3). Repo-128K raises FuncPass@1 by 4.0 pp but lowers SecPass@1 by 0.5 pp, so 128K tokens of repository code do not yield more security than a 4K-token slice.

Robustness. Rankings at native budgets agree with the common-cap ranking ($\tau_b = 0.89$), and excluding non-derivable tasks or near-copies leaves all rankings intact. On mutated tasks, SecPass@1 differs by at most 1.6 pp. With equal project weights, or without the six largest projects, effect sizes change slightly (e.g., Source-sink: +4.9 and +5.2 pp) but the ranking is preserved ($\tau_b = 0.81$).

Finding 1 (RQ1): Functionality-oriented context improves correctness more than security.

Functionality-oriented methods change FuncPass@1 by up to 8.2 pp but SecPass@1 by at most 3.7 pp, and none differs significantly from Local-only. Security-aware methods add 4.2-5.5 pp, with the largest gains of Source-sink on L3 tasks.

5.2 RQ2: Which Context Factors Help or Hurt, and Why Does Code Remain Insecure?

Amount. SecPass@1 of ReACC-Hybrid rises from 13.5% (Local-only) to 16.6% at 8K tokens and falls to 14.6% at 32K (Figure 5). Beyond 8K, its fix-API recall still grows, but so does the share of contexts with an insecure exemplar (from 41% to 90%), while security density drops from .19 to .06. The decline thus coincides with more exemplars rather than with lower recall. DevEval-Dep and RepoCoder-Iter already peak at 4K, Source-sink saturates at 8K because it adds few units beyond the slice, and Repo-128K stays at the Local-only level.

Removing and adding safeguards. Removing one safeguard role from the Reference context lowers SecPass@1 by 8.1 pp for the safe API, 6.7 pp for validators, 5.2 pp for the policy, and 3.9 pp for the caller contract (Figure 6a). On access-control tasks, removing the policy alone costs 11.3 pp. Removing the guards from the Source-sink slice shrinks its gain from +6.0 to +1.2 pp, and adding missing safeguards to the best method's context raises SecPass@1 by 5.9 pp. Most lost secure outputs (56-62%) become correct but exploitable, and the rest become incorrect, so part of the effect is functional. Replacing a removed role with irrelevant code of the same length at the same position yields nearly the same drops (3.6-7.7 pp), so length and position explain little of the effect.

Insecure exemplars. On the 74 tasks with an exemplar, inserting one exemplar into the Reference context raises CbE@1 by 6.3 pp although the safeguard remains present. In the context of the best functionality-oriented method, the same insertion raises CbE@1 by 4.8 pp. Irrelevant code of the same length at the same position raises it by only 0.6 pp, and appending 2K, 8K, or 32K tokens of irrelevant code raises it by at most 0.9 pp. What a context shows thus matters far more than how much it shows.

Presentation. The position effect grows with context length (Figure 6b): a safeguard in the middle costs 0.6 pp at 4K tokens but 5.9 pp at 64K, mirroring the lost-in-the-middle effect [35]. Renaming the safeguard costs 3.1 pp, more on web tasks (4.6 pp) than on

Table 3: RQ1: Outcomes per method and condition (rates in %, 6 models, 3 runs, 145 tasks). Context methods use the 8K retrieval cap. Δ: change relative to Local-only in pp; bold: at least the 3 pp practical-relevance threshold; †: Holm-adjusted $p < .05$ against Local-only. Best-of-methods selects, per task and model, the best functionality-oriented method on two runs and evaluates it on the third (cross-fitted, not deployable).

Method / condition	FuncPass@1	SecPass@1 [95% CI]	CbE@1	ΔFuncPass	ΔSecPass
Reference / control					
Local-only	56.9	12.6 [9.3, 16.2]	44.3	-	-
BM25+README	59.7	12.4 [9.1, 16.0]	47.3	+2.8	-0.2
Security reminder	55.1	13.9 [10.5, 17.6]	41.2	-1.8	+1.3
Placebo	56.2	12.9 [9.6, 16.5]	43.3	-0.7	+0.3
Repo-128K	60.9	12.1 [8.9, 15.6]	48.8	+4.0	-0.5
Functionality-oriented					
InCoder-FIM	57.4	12.8 [9.5, 16.4]	44.6	+0.5	+0.2
LongCoder-Mem	57.8	13.2 [9.9, 16.8]	44.6	+0.9	+0.6
ReACC-Hybrid	61.9	15.4 [11.9, 19.2]	46.5	+5.0	+2.8
CCEval-BM25	60.3	11.5 [8.3, 15.0]	48.8	+3.4	-1.1
RepoBench-R	52.1	11.8 [8.6, 15.3]	40.3	-4.8	-0.8
ProCC-Multi	65.1	14.9 [11.5, 18.6]	50.2	+8.2	+2.3
RepoCoder-Iter	55.0	12.9 [9.6, 16.5]	42.1	-1.9	+0.3
RLPG-Proposal	54.6	12.3 [9.0, 15.9]	42.3	-2.3	-0.3
DevEval-Dep	56.4	13.3 [10.0, 16.9]	43.1	-0.5	+0.7
SWE-agent-Ret	55.0	11.7 [8.5, 15.2]	43.3	-1.9	-0.9
ClaudeCode-Ret	63.8	16.3 [12.8, 20.1]	47.5	+6.9	**+3.7**
Security-aware					
CodeGuarder	58.8	16.8 [13.2, 20.7]	42.0	+1.9	**+4.2**
Source-sink	61.2	18.1 [14.4, 22.1]	43.1	+4.3	**+5.5**†
Diagnostic (not deployable)					
Reference context	62.3	24.8 [20.7, 29.2]	37.5	+5.4	**+12.2**
Best-of-methods	70.8	19.6 [15.8, 23.7]	-	-	+7.0

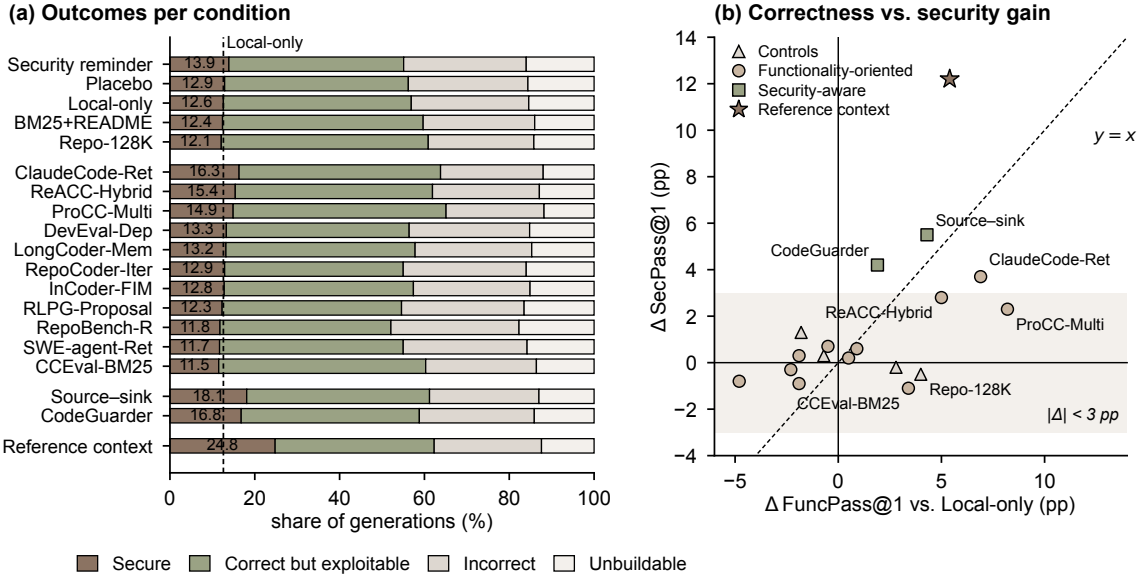

Figure 4: RQ1: (a) Outcome partition per condition (number: SecPass@1). (b) Change in FuncPass@1 versus change in SecPass@1 relative to Local-only; the shaded band marks changes below the 3 pp practical-relevance threshold.

Table 4: RQ1: SecPass@1 (%) by CWE family for selected conditions. "Best func." is the best functionality-oriented method (ClaudeCode-Ret); "Best-of" is the cross-fitted oracle.

Family	Tasks	Local-only	Best func.	Best-of	CodeGuarder	Source-sink	Reference
Memory safety	65	16.2	21.4	25.6	21.8	19.9	26.2
Injection	42	13.4	16.8	19.8	17.7	21.2	28.0
Access control	25	2.0	2.9	4.4	3.1	9.3	17.6
Other	13	12.0	15.0	17.9	15.4	15.8	20.9
All	145	12.6	16.3	19.6	16.8	18.1	24.8

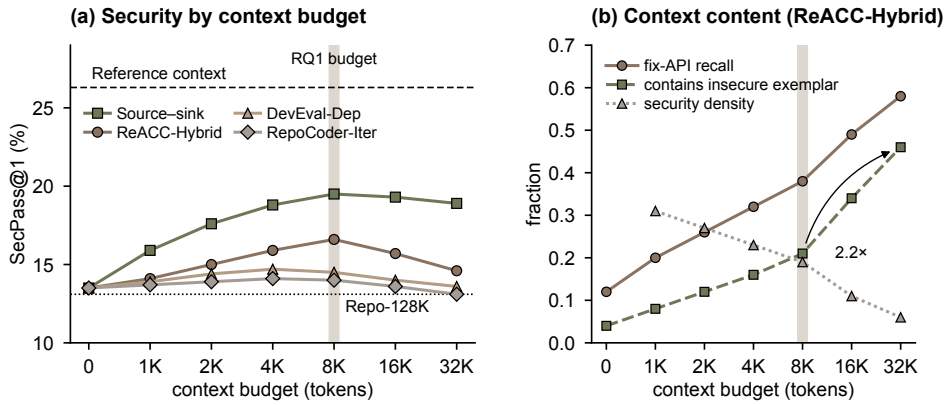

Figure 5: RQ2 (amount): (a) SecPass@1 by retrieval cap on the three RQ2 models (cap 0: Local-only; shaded: the 8K cap of RQ1). (b) Content of the ReACC-Hybrid context over all 145 tasks.

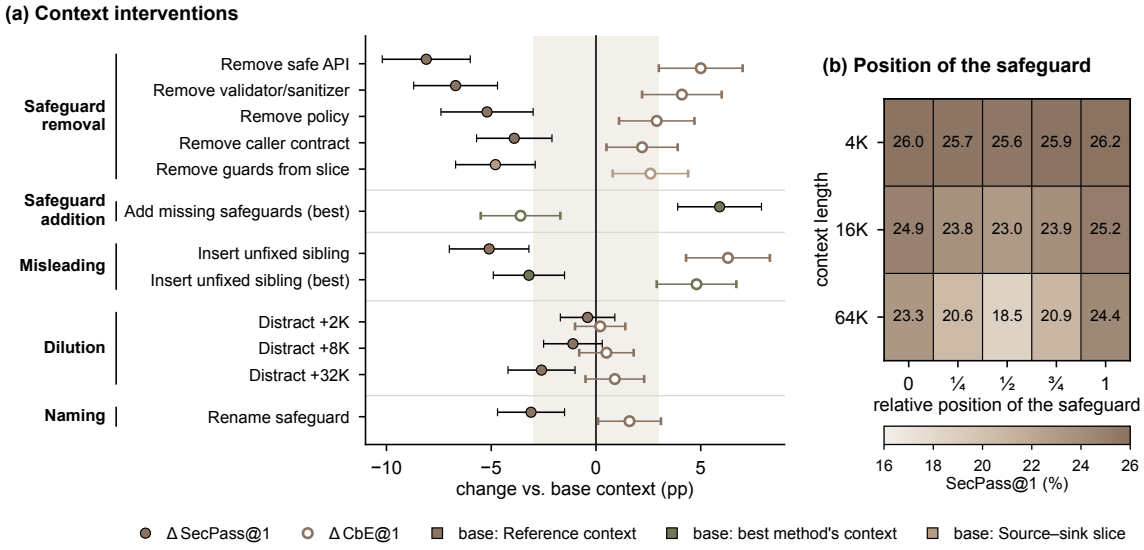

Figure 6: RQ2 (content and presentation): (a) Effects of context interventions on SecPass@1 (filled) and CbE@1 (hollow) relative to the unmodified base context on the same tasks and three models, with 95% intervals; the shaded band marks changes below 3 pp. "(best)": applied to the context of the best functionality-oriented method. (b) SecPass@1 of the Reference context by the relative position of the safeguard and the total context length.

memory-safety tasks (1.2 pp), which suggests that models partly recognize safeguards by name (e.g., *check_permission*).

Finding 2 (RQ2): Withheld safeguards and inserted exemplars reduce security.

Withholding a safeguard role costs 3.9-8.1 pp of SecPass@1, and supplying missing safeguards adds 5.9 pp. One inserted insecure exemplar raises CbE@1 by 6.3 pp despite the safeguard, whereas length-matched irrelevant code raises it by 0.6 pp.

Failure patterns. With functionality-oriented context, most correct-but-exploitable code lacks a safeguard (Missing) or imitates an exemplar (Imitated); with security-aware context, unused and misused safeguards become frequent (Table 5). The shift holds per 100 generations, so it is not an artifact of the denominator: Missing falls from 20.6 to 12.3, while Unused and Misused together rise from 10.7 to 21.3. It also appears within task-model pairs, where the dominant label moves from Missing to a utilization failure in 29% of pairs and in the reverse direction in 5%. Label precision ranges from .72 (Imitated) to .94 (Missing). In multi-location tasks, 14% of correct-but-exploitable generations guard the masked region locally but consume an unchecked value from an unfixed sibling, and open coding revealed two further patterns (e.g., defending against the wrong attack).

Finding 3 (RQ2): Remaining failures concentrate on applying retrieved safeguards.

With security-aware context, unused and misused safeguards rise from 10.7 to 21.3 per 100 generations, and the shift also appears within task-model pairs.

5.3 RQ3: Do Coding Agents Gather Security-Relevant Context?

Exploration. Agents raise FuncPass@1 over the best retrieval-based method with the same backbone by 2.7-7.1 pp but change SecPass@1 by only −1.3 to +0.5 pp (Table 6), consistent with prior agent studies [44, 49, 72]. Although agents observe 16-26× as many repository tokens as an 8K context, they observe the relevant safeguard in only 27-36% of trajectories, yet an insecure exemplar in 43-51% of the trajectories on tasks that contain one. Their searches target functionality: 71% of queries name functional entities (e.g., a file format), and only 9% name security concepts (Figure 7a). Manual validation agrees with this classification ($\kappa = 0.81$), and counting security intent regardless of wording raises the share only to 13%.

Observation and outcome. Trajectories that observed and used the safeguard reach 34.5% SecPass@1, versus 12.7% for those that never observed it (Figure 7b). In a mixed-effects model, observing the safeguard is associated with higher odds of a secure outcome (OR 2.4), whereas the scaffold difference is inconclusive (OR 1.2 [0.9, 1.6]). The association is observational, but in 81% of these trajectories the safeguard was observed before the first edit, and the association persists for such observations (OR 2.1). Between 5% and 11% of trajectories hit the step or cost cap, and excluding them changes SecPass@1 by at most 0.7 pp. Observation is not sufficient: 41% of the trajectories that observed a safeguard did not use it and reach only 15.8% SecPass@1. Conversely, trajectories that observed an insecure exemplar produce more correct-but-exploitable code (61.6% vs. 48.4%; Figure 7c).

Finding 4 (RQ3): Coding agents mostly search for functionality.

Agents observe the relevant safeguard in only 27-36% of trajectories, and most of their queries target functionality. Trajectories that observed the safeguard were more often secure.

5.4 Measurement Robustness: Does the Oracle Change the Conclusions?

Static analysis and the PoC oracle disagree on 36.8% of the 28,984 functionally correct RQ1 generations ($\kappa = 0.25$; Table 7), and the disagreement goes in both directions. Relative to the PoC verdict, static analysis has a precision of .87 and a recall of .60: it misses 40% of exploited generations (e.g., off-by-one bounds checks), and it flags 27% of the generations that resist the PoC, which may be false alarms or vulnerabilities that the PoC does not trigger. The same pattern appears on code with known verdicts: the queries miss 17% of the vulnerable versions and flag 13% of the patched ones. Exploit variants compromise 7.3% of the generations that resist the base PoC. On the same 145 tasks, the two oracles rank the methods only moderately alike ($\tau_b = 0.56$; Figure 8): static analysis favours ProCC-Multi and CodeGuarder, whereas the PoC oracle favours ClaudeCode-Ret and Source-sink. Comparative conclusions about context methods therefore depend on the oracle, and a static-only evaluation would have favoured methods whose code merely contains defensive patterns.

5.5 Case Study: A Repository-Specific Policy

We examine CVE-2022-2732 in OpenEMR (CWE-862, L3), the access-control task on which the conditions differ most (18 generations each). Before the fix, any authenticated user could amend a patient record through *add_edit_amendments.php*. The required permission appears only in a widget guard in *demographics.php* (Figure 9) and cannot be inferred from the requirement, while the target file and its sibling pages contain misleading or missing checks. Local-only produced no secure generation, and functionality-oriented methods produced at most three, because similarity retrieval favoured the unchecked siblings (Imitated). Following CodeGuarder's generic advice, generations checked only for a login, which the PoC user has, or demanded administrator rights, which rejects the legitimate clinician of the functional tests (1/18). ClaudeCode-Ret retrieved *demographics.php* but ranked it after the siblings (3/18), whereas Source-sink followed the request from its form to the database write and retrieved the guard (6/18). The Reference context yielded 12 secure generations, but four generations checked the permission only after the request had been processed (Misused). Retrieving the policy thus did not ensure its correct use on the attack path. Together with the motivating example, in which similarity retrieval exposed a guard, the case shows that the same method can help on one task and hurt on another, depending on whether similar code carries the safeguard.

6 Discussion

6.1 Implications

Why functionality-oriented retrieval misses safeguards. Our results suggest a common cause. Functionality-oriented methods build their queries from the target code and the requirement, which

Table 5: RQ2: Failure patterns of correct-but-exploitable code (21,945 CbE generations from the 19 RQ1 conditions). Labels may co-occur. "Share of CbE": percentage of the CbE generations of each group; "Per 100 gen.": the same pattern per 100 generations of the group, i.e., the share multiplied by the group's mean CbE@1 (44.9% and 42.6%). Both groups exclude the six controls and use the same tasks and models. Agreement of automatic and manual labels on 200 samples: $\kappa = 0.81$.

		Share of CbE			Per 100 gen.	
Pattern	Definition	All	Func.	Sec.	Func.	Sec.
Missing	no acceptable safeguard set (L2/L3)	44%	46%	29%	20.6	12.3
Knowledge	L1 task; generic defense omitted	13%	13%	12%	5.8	5.1
Unused	present, neither called nor replicated	16%	15%	28%	6.7	11.9
Misused	called, yet exploited	10%	9%	22%	4.0	9.4
Imitated	similar to an exemplar in context	19%	20%	9%	9.0	3.8
Other	wrong threat model, partial fix	6%	6%	8%	2.7	3.4

Table 6: RQ3: End-to-end agents versus the best retrieval-based generation method with the same backbone (145 tasks, $n = 3$). "Best": the functionality-oriented method with the highest RQ1 SecPass@1 for that generator. "SG obs.": share of trajectories (or contexts) that contain a safeguard; "IE obs.": the same for an insecure exemplar, on the 74 tasks that contain one; "Tokens": repository tokens observed.

Agent	Backbone	FuncPass@1	SecPass@1	CbE@1	SG obs.	IE obs.	Tokens	Cost
SWE-agent	Sonnet 4.5	69.7	16.6	53.1	29%	46%	141K	$1.08
SWE-agent	GPT-5.4	71.0	16.1	54.9	27%	43%	127K	$0.91
Claude Code	Sonnet 4.5	74.0	18.4	55.6	36%	51%	204K	$1.41
ClaudeCode-Ret (best)	Sonnet 4.5	66.9	17.9	49.0	22%	36%	7.2K	$0.09
ReACC-Hybrid (best)	GPT-5.4	68.3	17.0	51.3	19%	41%	7.8K	$0.05

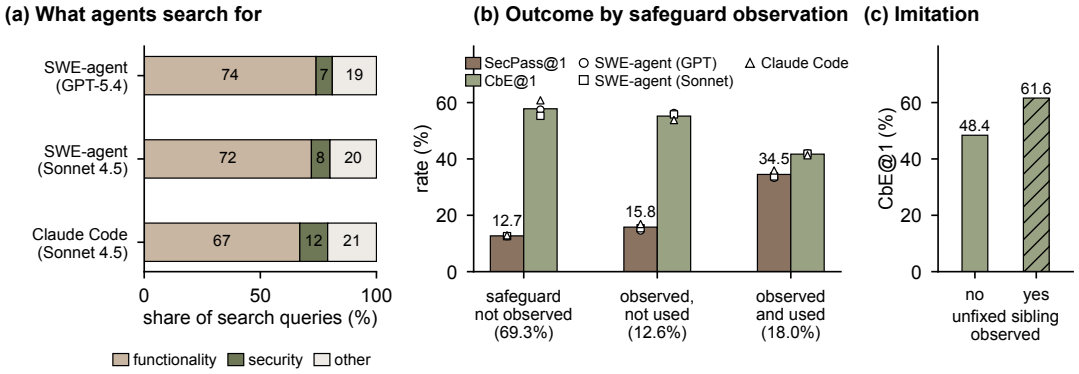

Figure 7: RQ3: (a) Share of search queries that name functional entities, security concepts, or other entities. (b) SecPass@1 and CbE@1 of agent trajectories by whether the safeguard was observed and used (bars: pooled; markers: agents; parentheses: share of trajectories). (c) CbE@1 by whether an insecure exemplar was observed, on the 74 tasks that contain one.

Table 7: Static analysis versus the PoC oracle on all 28,984 functionally correct RQ1 generations, and the base PoC versus exploit variants on 40 tasks.

	PoC fails	PoC succeeds	Summary	
StaticSecure	5,138	8,778	Agreement / κ	63.2% / 0.25
StaticAlarm	1,901	13,167	Precision / recall[†]	.87 / .60
Resists the base PoC, exploited by a variant (40 tasks)			Share	7.3%

[†] Static alarms are evaluated relative to the base PoC verdict; PoC-resistant alarms are not necessarily false positives.

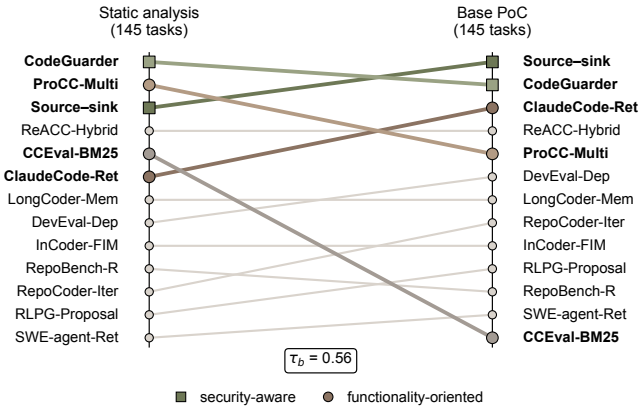

Figure 8: Rankings of the 13 methods by security under the static and the base-PoC oracle on the same 145 tasks (top: most secure).

describe *what* the code does rather than *which policy* constrains it. Safeguards, however, often live elsewhere in the repository (e.g., in a central access-control module), so they rarely resemble the target, whereas unfixed siblings resemble it closely. Agents show the same bias in their search queries (Finding 4), and longer contexts mainly add more siblings (§5.2). The motivating example illustrates the exception: similarity helps only when a sibling happens to carry the guard, which makes functionality-oriented retrieval an unreliable source of safeguards.

Retrieve safeguards explicitly. The removal experiments and the gains of Source-sink support retrieving the project's safeguards (e.g., validators and access policies), especially on L2 and L3 tasks (Findings 1 and 2). Context budgets should follow safeguard coverage rather than size, because larger contexts also expose more insecure exemplars. The annotations of CASE-Bench make such retrievers measurable, since safeguard coverage can be computed for any context before generation.

Check examples before reuse. An inserted insecure exemplar increases exploitable code even when a safeguard is present (Finding 2). Since similarity retrieval can surface both secure and insecure siblings (§2.2), retrieved examples should be checked for the required safeguards before they serve as templates. The static analyses that already run in many pipelines can serve this purpose, because an exemplar only needs to be flagged, not proven insecure.

Make agents security-aware. Agents rarely search for security concepts, and retrieved safeguards often remain unused or are misapplied (Findings 3 and 4). These results motivate, but do not validate, two directions: agents that search for the safeguards of a sensitive operation before editing it, and post-generation checks that a retrieved safeguard actually guards the untrusted value.

Evaluate context explicitly. Because the context changes which methods look best, secure-code benchmarks should treat it as an experimental variable. They should also report correct-but-exploitable code separately and pair functional tests with executable exploits, since static oracles alone rank methods differently (§5.4).

Future directions. Two directions follow from our results. First, context constructors could identify which kind of safeguard a task needs (e.g., a bounds check or an access policy) before retrieving, since methods are complementary across tasks. Second, CASE-Bench can serve as a testbed for such security-aware retrievers and agents, because its annotations allow measuring safeguard coverage before any generation. Extending it to feature-level tasks that span several files would test whether our findings hold when the edit scope is larger.

6.2 Threats to Validity

Construct validity. A PoC can demonstrate but not exclude a vulnerability, so SecPass@1 is relative to our tests and exploits; exploit variants change 7.3% of verdicts on 40 tasks, and a manual audit agrees with the oracle on 95.7% of generations. The failure labels are heuristic (precision .72-.94), and the static oracle is a single query configuration.

Internal validity. We compare reproduced context policies, which may deviate from the original systems in newly supported languages. The agent analysis is observational, and only the removal and insertion edits have matched controls. Mutated and recent tasks agree with the main results, but contamination cannot be ruled out.

External validity. The tasks come from 51 projects, and six projects contribute 67 tasks; reweighting projects preserves the pattern, but task characteristics (e.g., weakness type and language) remain partly confounded. Differences below about 5.6 pp may remain undetected, and the case study illustrates rather than quantifies the mechanisms.

7 Related Work

Security of LLM-generated code. Code assistants often suggest vulnerable code [45, 48]. Secure-code benchmarks have progressed from snippets with static or manual judgment [3, 19, 31, 53, 54, 57] to executable function-level and application-level tasks [6, 41, 44, 47, 58, 59], and then to repository-level tasks from real vulnerabilities [5, 32, 49, 61, 72] (Table 8). A.S.E [32] judges security with static rules. SecRepoBench [49] and RealSec-bench [61] find that agents and retrievers mainly improve correctness. Table 8 compares CASE-Bench with these benchmarks along the capabilities that a study of context requires. Executable functional and exploit oracles are increasingly common, and several benchmarks also evaluate agents. CASE-Bench differs from all of them in treating the context as the controlled variable and in annotating security-relevant code, which makes the content of a context measurable. Security-agent benchmarks [28, 29, 40, 62, 73] and vulnerability repair [4, 14, 46] start from a known vulnerability, whereas our models are never told that one exists. We share their emphasis on executable, effect-based verdicts, and like SEC-bench Pro [28], we find that the grading rule can change conclusions. Our validation and contamination checks follow SWE-bench Verified [42] and studies of evaluation leakage [39].

Context for repository-level code generation. Repository-level benchmarks show that generation depends on cross-file information. Such context [10, 24, 36, 67] is obtained by the method families of Table 2, by graph retrieval [8, 37, 43], or by agents [64, 70, 71]. Studies of retrieval [17, 27, 63] and long contexts [23, 35, 50] show that context can also hurt correctness, but they measure only whether code works. We show how these effects bear on security

```
// add_edit_amendments.php, masked region (lines 19–52): patched version, shown for the reader only
if (!AclMain::aclCheckCore('patients', 'amendment')) { /* render unauthorized page */ exit; }
// same file, below the masked region: a different ACL object, used only to render the form    (misleading)
$haveAccess = AclMain::aclCheckCore('patients', 'trans');   $onlyRead = ($haveAccess) ? 0 : 1;
// demographics.php: the project's amendment policy                                            (safeguard)
'auth' => AclMain::aclCheckCore('patients', 'amendment', '', 'write'),
// list_amendments.php, print_amendments.php: no check at all                          (unfixed siblings)
```

Figure 9: Security-relevant code of CVE-2022-2732 (OpenEMR). The masked region is shown in its patched version for the reader (bold: added by the fix); the model sees the target file without it. All other code is at the base commit.

Table 8: Repository-level benchmarks for the security of LLM-generated code. "Func.": tests check functionality; "Exploit": an executable exploit checks security; "Context": context is the controlled variable (SecRepoBench and RealSec-bench compare a few retrievers secondarily); "Annot.": security-relevant code annotated.

Benchmark	Lang.	Tasks	Real CVEs	Func.	Exploit	Context	Agents	Annot.
A.S.E [32]	5	120	✓	✗	✗	✗	✗	✗
SecRepoBench [49]	2	318	✓	✓	✓	✗	✓	✗
RealSec-bench [61]	1	105	✓	✓	✗	✗	✗	✗
SecureVibeBench [5]	2	105	✓	✓	✓	✗	✓	✗
SusVibes [72]	1	200	✓	✓	✓	✗	✓	✗
CASE-Bench (ours)	7	145	✓	✓	✓	✓	✓	✓

and identify a mechanism that correctness studies cannot observe: the imitation of insecure exemplars.

Improving the security of generated code. Model-side techniques (e.g., security hardening [20, 21] or constrained decoding [15]) and prompting [56] change the model or the instruction. Retrieval-based approaches add *external* security knowledge [34, 51, 68] or show that poisoned corpora induce vulnerable code [33]. We instead study the context that the repository itself provides, which is benign but can still mislead, and we include CodeGuarder as a representative of external knowledge.

8 Conclusion

In this paper, we constructed CASE-Bench, an executable and annotated benchmark for studying how repository context affects the security of LLM-generated code. Using CASE-Bench, we conducted a controlled study of 13 context construction methods with six LLMs, together with single-element context edits and an analysis of coding-agent trajectories. We revealed that functionality-oriented context improves correctness more than security, that withheld safeguards and inserted insecure exemplars reduce security, and that coding agents rarely search for security-relevant code. Based on these findings, we provided guidelines for retrieving project safeguards and checking retrieved examples. We believe that our work lays the groundwork for security-aware context construction in LLM coding assistants.

References

[1] Andrea Arcuri and Lionel Briand. 2011. A Practical Guide for Using Statistical Tests to Assess Randomized Algorithms in Software Engineering. In *Proceedings of the 33rd International Conference on Software Engineering (ICSE)*. 1–10. doi:10.1145/1985793.1985795

[2] Douglas Bates, Martin Mächler, Ben Bolker, and Steve Walker. 2015. Fitting Linear Mixed-Effects Models Using lme4. *Journal of Statistical Software* 67, 1 (2015), 1–48. doi:10.18637/jss.v067.i01

[3] Manish Bhatt, Sahana Chennabasappa, Cyrus Nikolaidis, Shengye Wan, Ivan Evtimov, Dominik Gabi, Daniel Song, Faizan Ahmad, Cornelius Aschermann, Lorenzo Fontana, et al. 2023. Purple Llama CyberSecEval: A Secure Coding Benchmark for Language Models. *arXiv preprint arXiv:2312.04724* (2023).

[4] Quang-Cuong Bui, Riccardo Scandariato, and Nicolás E. Díaz Ferreyra. 2022. Vul4J: A Dataset of Reproducible Java Vulnerabilities Geared Towards the Study of Program Repair Techniques. In *Proceedings of the 19th International Conference on Mining Software Repositories (MSR)*. 464–468. doi:10.1145/3524842.3528482

[5] Junkai Chen, Huihui Huang, Yunbo Lyu, Junwen An, Jieke Shi, Chengran Yang, Ting Zhang, Haoye Tian, Yikun Li, Zhenhao Li, Xin Zhou, Xing Hu, and David Lo. 2026. SecureVibeBench: Benchmarking Secure Vibe Coding of AI Agents via Reconstructing Vulnerability-Introducing Scenarios. In *Proceedings of the 64th Annual Meeting of the Association for Computational Linguistics (ACL)*. arXiv:2509.22097 (earlier title: SecureAgentBench).

[6] Longfei Chen, Ji Zhao, Lanxiao Cui, Tong Su, Xingbo Pan, Ziyang Li, Yongxing Wu, Qijiang Cao, Qiyao Cai, Jing Zhang, et al. 2026. SecCodeBench-V2 Technical Report. *arXiv preprint arXiv:2602.15485* (2026).

[7] Mark Chen, Jerry Tworek, Heewoo Jun, Qiming Yuan, Henrique Ponde de Oliveira Pinto, Jared Kaplan, Harri Edwards, Yuri Burda, Nicholas Joseph, Greg Brockman, et al. 2021. Evaluating Large Language Models Trained on Code. *arXiv preprint arXiv:2107.03374* (2021).

[8] Wei Cheng, Yuhan Wu, and Wei Hu. 2024. Dataflow-Guided Retrieval Augmentation for Repository-Level Code Completion. In *Proceedings of the 62nd Annual Meeting of the Association for Computational Linguistics (ACL)*. 7957–7977. doi:10.18653/v1/2024.acl-long.431

[9] Jacob Cohen. 1960. A Coefficient of Agreement for Nominal Scales. *Educational and Psychological Measurement* 20, 1 (1960), 37–46. doi:10.1177/001316446002000104

[10] Yangruibo Ding, Zijian Wang, Wasi Uddin Ahmad, Hantian Ding, Ming Tan, Nihal Jain, Murali Krishna Ramanathan, Ramesh Nallapati, Parminder Bhatia, Dan Roth, and Bing Xiang. 2023. CrossCodeEval: A Diverse and Multilingual Benchmark for Cross-File Code Completion. In *Advances in Neural Information Processing Systems 36 (NeurIPS), Datasets and Benchmarks Track*. 46701–46723.

[11] Yufeng Du, Minyang Tian, Srikanth Ronanki, Subendhu Rongali, Sravan Babu Bodapati, Aram Galstyan, Azton Wells, Roy Schwartz, Eliu A. Huerta, and Hao Peng. 2025. Context Length Alone Hurts LLM Performance Despite Perfect Retrieval. In *Findings of the Association for Computational Linguistics: EMNLP 2025*. 23281–23298.

[12] Bradley Efron and Robert J. Tibshirani. 1994. *An Introduction to the Bootstrap*. Chapman & Hall/CRC.

[13] Daniel Fried, Armen Aghajanyan, Jessy Lin, Sida Wang, Eric Wallace, Freda Shi, Ruiqi Zhong, Wen-tau Yih, Luke Zettlemoyer, and Mike Lewis. 2023. InCoder: A Generative Model for Code Infilling and Synthesis. In *Proceedings of the 11th International Conference on Learning Representations (ICLR)*.

[14] Michael Fu, Chakkrit Tantithamthavorn, Trung Le, Van Nguyen, and Dinh Phung. 2022. VulRepair: A T5-Based Automated Software Vulnerability Repair. In *Proceedings of the 30th ACM Joint European Software Engineering Conference and Symposium on the Foundations of Software Engineering (ESEC/FSE)*. 935–947.

doi:10.1145/3540250.3549098
[15] Yanjun Fu, Ethan Baker, Yu Ding, and Yizheng Chen. 2024. Constrained Decoding for Secure Code Generation. *arXiv preprint arXiv:2405.00218* (2024).
[16] GitHub. [n. d.]. CodeQL. https://codeql.github.com. Accessed: 2026-10-03.
[17] Wenchao Gu, Juntao Chen, Yanlin Wang, Tianyue Jiang, Xingzhe Li, Mingwei Liu, Xilin Liu, Yuchi Ma, and Zibin Zheng. 2025. What to Retrieve for Effective Retrieval-Augmented Code Generation? An Empirical Study and Beyond. *arXiv preprint arXiv:2503.20589* (2025).
[18] Daya Guo, Canwen Xu, Nan Duan, Jian Yin, and Julian McAuley. 2023. LongCoder: A Long-Range Pre-trained Language Model for Code Completion. In *Proceedings of the 40th International Conference on Machine Learning (ICML)*.
[19] Hossein Hajipour, Keno Hassler, Thorsten Holz, Lea Schönherr, and Mario Fritz. 2024. CodeLMSec Benchmark: Systematically Evaluating and Finding Security Vulnerabilities in Black-Box Code Language Models. In *Proceedings of the 2024 IEEE Conference on Secure and Trustworthy Machine Learning (SaTML)*. 684–709. doi:10.1109/SaTML59370.2024.00040
[20] Jingxuan He and Martin Vechev. 2023. Large Language Models for Code: Security Hardening and Adversarial Testing. In *Proceedings of the 2023 ACM SIGSAC Conference on Computer and Communications Security (CCS)*. 1865–1879. doi:10.1145/3576915.3623175
[21] Jingxuan He, Mark Vero, Gabriela Krasnopolska, and Martin Vechev. 2024. Instruction Tuning for Secure Code Generation. In *Proceedings of the 41st International Conference on Machine Learning (ICML)*.
[22] Sture Holm. 1979. A Simple Sequentially Rejective Multiple Test Procedure. *Scandinavian Journal of Statistics* 6, 2 (1979), 65–70.
[23] Cheng-Ping Hsieh, Simeng Sun, Samuel Kriman, Shantanu Acharya, Dima Rekesh, Fei Jia, Yang Zhang, and Boris Ginsburg. 2024. RULER: What's the Real Context Size of Your Long-Context Language Models?. In *Proceedings of the 1st Conference on Language Modeling (COLM)*.
[24] Carlos E. Jimenez, John Yang, Alexander Wettig, Shunyu Yao, Kexin Pei, Ofir Press, and Karthik Narasimhan. 2024. SWE-bench: Can Language Models Resolve Real-World GitHub Issues?. In *Proceedings of the 12th International Conference on Learning Representations (ICLR)*.
[25] Joern Project. [n. d.]. Joern: The Bug Hunter's Workbench. https://joern.io. Accessed: 2026-10-03.
[26] Maurice G. Kendall. 1938. A New Measure of Rank Correlation. *Biometrika* 30, 1/2 (1938), 81–93. doi:10.2307/2332226
[27] Nam Le Hai, Dung Manh Nguyen, and Nghi D. Q. Bui. 2025. On the Impacts of Contexts on Repository-Level Code Generation. In *Findings of the Association for Computational Linguistics: NAACL 2025*. 1496–1524. doi:10.18653/v1/2025.findings-naacl.82
[28] Hwiwon Lee, Jiawei Liu, Dongjun Kim, Wubing Xia, Ziqi Zhang, Chunqiu Steven Xia, and Lingming Zhang. 2026. SEC-bench Pro: Can Language Models Solve Long-Horizon Software Security Tasks? *arXiv preprint arXiv:2605.26548* (2026).
[29] Hwiwon Lee, Ziqi Zhang, Hanxiao Lu, and Lingming Zhang. 2025. SEC-bench: Automated Benchmarking of LLM Agents on Real-World Software Security Tasks. In *Advances in Neural Information Processing Systems 38 (NeurIPS)*.
[30] Jia Li, Ge Li, Yunfei Zhao, Yongmin Li, Huanyu Liu, Hao Zhu, Lecheng Wang, Kaibo Liu, Zheng Fang, Lanshen Wang, et al. 2024. DevEval: A Manually-Annotated Code Generation Benchmark Aligned with Real-World Code Repositories. In *Proceedings of the 62nd Annual Meeting of the Association for Computational Linguistics (ACL)*.
[31] Xinghang Li, Jingzhe Ding, Chao Peng, Bing Zhao, Xiang Gao, Hongwan Gao, and Xinchen Gu. 2025. SafeGenBench: A Benchmark Framework for Security Vulnerability Detection in LLM-Generated Code. *arXiv preprint arXiv:2506.05692* (2025).
[32] Keke Lian, Bin Wang, Lei Zhang, Libo Chen, Junjie Wang, Ziming Zhao, Yujiu Yang, Miaoqian Lin, Haotong Duan, Haoran Zhao, et al. 2026. A.S.E: A Repository-Level Benchmark for Evaluating Security in AI-Generated Code. In *Findings of the Association for Computational Linguistics: ACL 2026*. arXiv:2508.18106.
[33] Bo Lin, Shangwen Wang, Liqian Chen, and Xiaoguang Mao. 2025. Exploring the Security Threats of Knowledge Base Poisoning in Retrieval-Augmented Code Generation. *arXiv preprint arXiv:2502.03233* (2025).
[34] Bo Lin, Shangwen Wang, Yihao Qin, Liqian Chen, and Xiaoguang Mao. 2025. Give LLMs a Security Course: Securing Retrieval-Augmented Code Generation via Knowledge Injection. In *Proceedings of the 2025 ACM SIGSAC Conference on Computer and Communications Security (CCS)*. 3356–3370. doi:10.1145/3719027.3765049
[35] Nelson F. Liu, Kevin Lin, John Hewitt, Ashwin Paranjape, Michele Bevilacqua, Fabio Petroni, and Percy Liang. 2024. Lost in the Middle: How Language Models Use Long Contexts. *Transactions of the Association for Computational Linguistics* 12 (2024), 157–173. doi:10.1162/tacl_a_00638
[36] Tianyang Liu, Canwen Xu, and Julian McAuley. 2024. RepoBench: Benchmarking Repository-Level Code Auto-Completion Systems. In *Proceedings of the 12th International Conference on Learning Representations (ICLR)*.
[37] Wei Liu, Ailun Yu, Daoguang Zan, Bo Shen, Wei Zhang, Haiyan Zhao, Zhi Jin, and Qianxiang Wang. 2024. GraphCoder: Enhancing Repository-Level Code Completion via Coarse-to-fine Retrieval Based on Code Context Graph. In *Proceedings of the 39th IEEE/ACM International Conference on Automated Software Engineering (ASE)*. 570–581. doi:10.1145/3691620.3695054
[38] Shuai Lu, Nan Duan, Hojae Han, Daya Guo, Seung-won Hwang, and Alexey Svyatkovskiy. 2022. ReACC: A Retrieval-Augmented Code Completion Framework. In *Proceedings of the 60th Annual Meeting of the Association for Computational Linguistics (ACL)*.
[39] Alexandre Matton, Tom Sherborne, Dennis Aumiller, Elena Tommasone, Milad Alizadeh, Jingyi He, Raymond Ma, Maxime Voisin, Ellen Gilsenan-McMahon, and Matthias Gallé. 2024. On Leakage of Code Generation Evaluation Datasets. In *Findings of the Association for Computational Linguistics: EMNLP 2024*. 13215–13223. doi:10.18653/v1/2024.findings-emnlp.772
[40] Xiang Mei, Pulkit Singh Singaria, Jordi Del Castillo, Haoran Xi, Tiffany Bao, Ruoyu Wang, Yan Shoshitaishvili, Adam Doupé, Hammond Pearce, and Brendan Dolan-Gavitt. 2024. ARVO: Atlas of Reproducible Vulnerabilities for Open Source Software. *arXiv preprint arXiv:2408.02153* (2024).
[41] Yuzhou Nie, Zhun Wang, Yu Yang, Ruizhe Jiang, Yuheng Tang, Xander Davies, Yarin Gal, Bo Li, Wenbo Guo, and Dawn Song. 2025. SeCodePLT: A Unified Platform for Evaluating the Security of Code GenAI. In *Advances in Neural Information Processing Systems (NeurIPS), Datasets and Benchmarks Track*.
[42] OpenAI. 2024. Introducing SWE-bench Verified. https://openai.com/index/introducing-swe-bench-verified/.
[43] Siru Ouyang, Wenhao Yu, Kaixin Ma, Zilin Xiao, Zhihan Zhang, Mengzhao Jia, Jiawei Han, Hongming Zhang, and Dong Yu. 2025. RepoGraph: Enhancing AI Software Engineering with Repository-level Code Graph. In *Proceedings of the 13th International Conference on Learning Representations (ICLR)*.
[44] Rupam Patir, Keyan Guo, Suvadra Barua, Abhijeet Pathak, Dinesh Gudimetla, Jiawei Guo, Hongxin Hu, and Haipeng Cai. 2025. DualGauge: Automated Joint Security-Functionality Benchmarking of Specification-Only Code Generation by LLMs and Coding Agents. *arXiv preprint arXiv:2511.20709* (2025).
[45] Hammond Pearce, Baleegh Ahmad, Benjamin Tan, Brendan Dolan-Gavitt, and Ramesh Karri. 2022. Asleep at the Keyboard? Assessing the Security of GitHub Copilot's Code Contributions. In *Proceedings of the 2022 IEEE Symposium on Security and Privacy (SP)*. 754–768. doi:10.1109/SP46214.2022.9833571
[46] Hammond Pearce, Benjamin Tan, Baleegh Ahmad, Ramesh Karri, and Brendan Dolan-Gavitt. 2023. Examining Zero-Shot Vulnerability Repair with Large Language Models. In *Proceedings of the 2023 IEEE Symposium on Security and Privacy (SP)*. 2339–2356. doi:10.1109/SP46215.2023.10179324
[47] Jinjun Peng, Leyi Cui, Kele Huang, Junfeng Yang, and Baishakhi Ray. 2025. CWEval: Outcome-driven Evaluation on Functionality and Security of LLM Code Generation. In *Proceedings of the 2025 IEEE/ACM International Workshop on Large Language Models for Code (LLM4Code)*. 33–40. doi:10.1109/LLM4Code66737.2025.00009
[48] Neil Perry, Megha Srivastava, Deepak Kumar, and Dan Boneh. 2023. Do Users Write More Insecure Code with AI Assistants?. In *Proceedings of the 2023 ACM SIGSAC Conference on Computer and Communications Security (CCS)*. 2785–2799. doi:10.1145/3576915.3623157
[49] Chihao Shen, Connor Dilgren, Purva Chiniya, Luke Griffith, Yu Ding, and Yizheng Chen. 2026. SecRepoBench: Benchmarking Code Agents for Secure Code Completion in Real-World Repositories. In *Proceedings of the 3rd IEEE/ACM International Workshop on Large Language Models for Code (LLM4Code)*. doi:10.1145/3786181.3788703 arXiv:2504.21205.
[50] Freda Shi, Xinyun Chen, Kanishka Misra, Nathan Scales, David Dohan, Ed Chi, Nathanael Schärli, and Denny Zhou. 2023. Large Language Models Can Be Easily Distracted by Irrelevant Context. In *Proceedings of the 40th International Conference on Machine Learning (ICML)*.
[51] Jiahao Shi and Tianyi Zhang. 2026. RESCUE: Retrieval Augmented Secure Code Generation. In *Proceedings of the 14th International Conference on Learning Representations (ICLR)*. arXiv:2510.18204.
[52] Disha Shrivastava, Hugo Larochelle, and Daniel Tarlow. 2023. Repository-Level Prompt Generation for Large Language Models of Code. In *Proceedings of the 40th International Conference on Machine Learning (ICML)*.
[53] Mohammed Latif Siddiq and Joanna C. S. Santos. 2022. SecurityEval Dataset: Mining Vulnerability Examples to Evaluate Machine Learning-Based Code Generation Techniques. In *Proceedings of the 1st International Workshop on Mining Software Repositories Applications for Privacy and Security (MSR4P&S)*. 29–33. doi:10.1145/3549035.3561184
[54] Mohammed Latif Siddiq, Joanna C. S. Santos, Sajith Devareddy, and Anna Muller. 2024. SALLM: Security Assessment of Generated Code. In *Proceedings of the 39th IEEE/ACM International Conference on Automated Software Engineering Workshops (ASEW)*.
[55] Hanzhuo Tan, Qi Luo, Ling Jiang, Zizheng Zhan, Jing Li, Haotian Zhang, and Yuqun Zhang. 2024. Prompt-based Code Completion via Multi-Retrieval Augmented Generation. *arXiv preprint arXiv:2405.07530* (2024).
[56] Catherine Tony, Nicolás E. Díaz Ferreyra, Markus Mutas, Salem Dhif, and Riccardo Scandariato. 2025. Prompting Techniques for Secure Code Generation: A Systematic Investigation. *ACM Transactions on Software Engineering and Methodology* 34, 8 (2025), 1–53. doi:10.1145/3722108

[57] Catherine Tony, Markus Mutas, Nicolás E. Díaz Ferreyra, and Riccardo Scandariato. 2023. LLMSecEval: A Dataset of Natural Language Prompts for Security Evaluations. In *Proceedings of the 20th IEEE/ACM International Conference on Mining Software Repositories (MSR)*. 588–592. doi:10.1109/MSR59073.2023.00084

[58] Mark Vero, Niels Mündler, Victor Chibotaru, Veselin Raychev, Maximilian Baader, Nikola Jovanović, Jingxuan He, and Martin Vechev. 2025. BaxBench: Can LLMs Generate Correct and Secure Backends?. In *Proceedings of the 42nd International Conference on Machine Learning (ICML)*.

[59] Jiexin Wang, Liuwen Cao, Xitong Luo, Yang Cao, Zhenghao Li, Yunyi Xiao, Mengchen Zhao, Adam Jatowt, and Yi Cai. 2026. Toward Secure Code Generation: Bridging Correctness and Security via Task-Adaptive Vulnerability Modeling and Execution-Based Benchmarking. In *Proceedings of the ACM SIGSOFT International Symposium on Software Testing and Analysis (ISSTA)*. arXiv:2407.02395.

[60] Xingyao Wang, Boxuan Li, Yufan Song, Frank F. Xu, Xiangru Tang, Mingchen Zhuge, Jiayi Pan, Yueqi Song, Bowen Li, Jaskirat Singh, Hoang H. Tran, Fuqiang Li, Ren Ma, Mingzhang Zheng, Bill Qian, Yanjun Shao, Niklas Muennighoff, Yizhe Zhang, Binyuan Hui, Junyang Lin, and et al. 2025. OpenHands: An Open Platform for AI Software Developers as Generalist Agents. In *ICLR*. OpenReview.net.

[61] Yanlin Wang, Ziyao Zhang, Chong Wang, Xinyi Xu, Mingwei Liu, Yong Wang, Jiachi Chen, and Zibin Zheng. 2026. RealSec-bench: A Benchmark for Evaluating Secure Code Generation in Real-World Repositories. In *Findings of the Association for Computational Linguistics: ACL 2026*. arXiv:2601.22706.

[62] Zhun Wang, Tianneng Shi, Jingxuan He, Matthew Cai, Jialin Zhang, and Dawn Song. 2026. CyberGym: Evaluating AI Agents' Real-World Cybersecurity Capabilities at Scale. In *Proceedings of the 14th International Conference on Learning Representations (ICLR)*.

[63] Zora Zhiruo Wang, Akari Asai, Xinyan Velocity Yu, Frank F. Xu, Yiqing Xie, Graham Neubig, and Daniel Fried. 2025. CodeRAG-Bench: Can Retrieval Augment Code Generation?. In *Findings of the Association for Computational Linguistics: NAACL 2025*. 3199–3214. doi:10.18653/v1/2025.findings-naacl.176

[64] Chunqiu Steven Xia, Yinlin Deng, Soren Dunn, and Lingming Zhang. 2025. Demystifying LLM-Based Software Engineering Agents. *Proceedings of the ACM on Software Engineering* 2, FSE (2025), 801–824. doi:10.1145/3715754

[65] Chunqiu Steven Xia, Yinlin Deng, and Lingming Zhang. 2024. Top Leaderboard Ranking = Top Coding Proficiency, Always? EvoEval: Evolving Coding Benchmarks via LLM. *arXiv preprint arXiv:2403.19114* (2024).

[66] John Yang, Carlos E. Jimenez, Alexander Wettig, Kilian Lieret, Shunyu Yao, Karthik Narasimhan, and Ofir Press. 2024. SWE-agent: Agent-Computer Interfaces Enable Automated Software Engineering. In *Advances in Neural Information Processing Systems 37 (NeurIPS)*.

[67] Hao Yu, Bo Shen, Dezhi Ran, Jiaxin Zhang, Qi Zhang, Yuchi Ma, Guangtai Liang, Ying Li, Qianxiang Wang, and Tao Xie. 2024. CoderEval: A Benchmark of Pragmatic Code Generation with Generative Pre-trained Models. In *Proceedings of the IEEE/ACM 46th International Conference on Software Engineering (ICSE)*. 1–12. doi:10.1145/3597503.3623316

[68] Boyu Zhang, Tianyu Du, Junkai Tong, Xuhong Zhang, Kingsum Chow, Sheng Cheng, Xun Wang, and Jianwei Yin. 2024. SecCoder: Towards Generalizable and Robust Secure Code Generation. In *Proceedings of the 2024 Conference on Empirical Methods in Natural Language Processing (EMNLP)*.

[69] Fengji Zhang, Bei Chen, Yue Zhang, Jacky Keung, Jin Liu, Daoguang Zan, Yi Mao, Jian-Guang Lou, and Weizhu Chen. 2023. RepoCoder: Repository-Level Code Completion Through Iterative Retrieval and Generation. In *Proceedings of the 2023 Conference on Empirical Methods in Natural Language Processing (EMNLP)*.

[70] Kechi Zhang, Jia Li, Ge Li, Xianjie Shi, and Zhi Jin. 2024. CodeAgent: Enhancing Code Generation with Tool-Integrated Agent Systems for Real-World Repo-level Coding Challenges. In *Proceedings of the 62nd Annual Meeting of the Association for Computational Linguistics (ACL)*.

[71] Yuntong Zhang, Haifeng Ruan, Zhiyu Fan, and Abhik Roychoudhury. 2024. AutoCodeRover: Autonomous Program Improvement. In *Proceedings of the 33rd ACM SIGSOFT International Symposium on Software Testing and Analysis (ISSTA)*. 1592–1604. doi:10.1145/3650212.3680384

[72] Songwen Zhao, Danqing Wang, Kexun Zhang, Jiaxuan Luo, Zhuo Li, and Lei Li. 2026. Is Vibe Coding Safe? Benchmarking Vulnerability of Agent-Generated Code in Real-World Tasks. In *Proceedings of the 43rd International Conference on Machine Learning (ICML)*. arXiv:2512.03262.

[73] Yuxuan Zhu, Antony Kellermann, Dylan Bowman, Philip Li, Akul Gupta, Adarsh Danda, Richard Fang, Conner Jensen, Eric Ihli, Jason Benn, et al. 2025. CVE-Bench: A Benchmark for AI Agents' Ability to Exploit Real-World Web Application Vulnerabilities. In *Proceedings of the 42nd International Conference on Machine Learning (ICML)*. 79850–79867.